MATRIZ DE REMEDIACIÓN DE SEGURIDAD WEB

AUDITORÍA TÉCNICA Y EVALUACIÓN DE HALLAZGOS

Resumen de Vulnerabilidades e Intervenciones

HALLAZGO DETECTADO	CRITICIDAD	ACCIÓN CORRECTORA APLICADA	ESTATUS
CSP: Uso de Comodines	MEDIO	Configuración estricta en Program.cs mediante la política Content-Security-Policy, restringiendo los orígenes a 'self' y suprimiendo el uso del carácter comodín (*).	Solucionado
CSP: Ausencia de Regla Form-Action	MEDIO	Inclusión explícita del parámetro form-action 'self' dentro del encabezado CSP para restringir el envío de formularios exclusivamente al dominio de origen.	Solucionado
CSP: Script Inseguro Inline	MEDIO	Bloqueo de Scripts inline eliminando el valor 'unsafe-inline' del atributo script-src dentro de las cabeceras CSP del servidor.	Solucionado
CSP: Estilos Inseguros Inline	MEDIO	Remoción de la directiva 'unsafe-inline' en la propiedad style-src, bloqueando la carga de hojas de estilo no verificadas.	Solucionado
Falta de Encabezado X-Content-Type-Options	BAJO	Implementación del middleware en ASP.NET Core para forzar la cabecera HTTP X-Content-Type-Options: nosniff, previniendo la interpretación errónea del tipo MIME.	Solucionado
Arquitectura de Aplicación Web Moderna	INFORMATIVO	Registro informativo sin necesidad de intervención técnica. Responde al rastreo de eventos dinámicos y navegación SPA.	Informativo
Fuga de Información: Comentarios en Código	INFORMATIVO	Sin requerimiento de ajuste. Notificación referente a comentarios estándar del framework dentro del componente ReconnectModal.razor.js de Blazor.	Informativo
Detección de Mecanismo de Sesión	INFORMATIVO	Sin requerimiento de ajuste. Confirma el uso nativo de tokens de validación .AspNetCore.Antiforgery propios del entorno de desarrollo.	Informativo

ANÁLISIS DE RESULTADOS DE LA AUDITORÍA

Vulnerabilidades de Riesgo Medio y Bajo (Mitigadas)

Todas las anomalías catalogadas en el reporte previo como nivel Medio (asociadas a la directiva Content-Security-Policy) y nivel Bajo (ausencia de X-Content-Type-Options) fueron subsanadas satisfactoriamente. Esto se logró integrando políticas de seguridad HTTP en la capa intermedia (middleware) de ASP.NET Core mediante Program.cs. En la evaluación posterior, se confirmó la remoción completa de amenazas en los niveles Alto, Medio y Bajo.

Avisos de Nivel Informativo

Los tres registros remanentes corresponden a comportamientos esperados y de bajo impacto vinculados a la arquitectura interna de Blazor Server (notaciones dentro de ReconnectModal.razor.js, patrones de tokens contra falsificación de peticiones y detección de Single Page Applications). Al ser de carácter exclusivamente informativo, no comprometen la seguridad del sistema.